
Report on the Elaboration of the Bachelor's Thesis

Faculty of Economic Sciences, Lucian Blaga University of Sibiu

Study programme: *Business Informatics*

Student: *Diana-Maria MITEA*

Scientific coordinator: *Associate Professor, Ph.D. Eduard Alexandru STOICA*

Academic year: *2025-2026*

THESIS TITLE: Understanding What You Are Clicking: Automated Analysis and Comparison of Website Privacy Policies

Resonate: Understanding What You Are Clicking: Automated Analysis And Comparison Of Website Privacy Policies

(a) General Aspects - Regarding the Thesis

What is the research topic? The research topic focuses on the automated analysis and comparison of website privacy policies, specifically investigating the operational gap between legally mandated privacy compliance and the actual technical tracking implementations utilized by websites.

Why is this topic worth investigating? Who is it important for? The modern digital economy heavily relies on the extraction and algorithmic analysis of personal data. This topic is critical to investigate because, despite robust legal frameworks like the General Data Protection Regulation (GDPR), the digital ecosystem is severely defective. It is important for:

- **End Consumers:** They currently face immense information friction from lengthy legal documents and lack intuitive diagnostic tools to verify if their privacy choices are respected.
- **Regulatory Bodies (e.g., Data Protection Authorities):** It highlights how current reliance on company self-reporting and manual audits is inadequate.
- **The Digital Advertising Industry:** It challenges the underlying economic drivers, specifically Real-Time Bidding (RTB) networks, that incentivize deceptive data harvesting.

What makes it original? The originality of the thesis lies in the design and deployment of the *Privacy Policy Analyzer & Cookie Trax*, a localized, zero-trust browser extension built in Manifest V3. Instead of relying on cloud servers that compromise user privacy, the tool operates a dual-engine client-side architecture. It cross-references static Natural Language Processing (NLP) of legal policies with dynamic, live browser storage auditing to expose "compliance theater" and pre-consent tracking.

What are the research questions and objectives? The primary objective is to bridge the systemic gap between theoretical privacy claims and practical technological implementations. The specific objectives are:

1. **Automated Static Analysis:** To develop a lightweight NLP system that extracts context-aware privacy risks from complex legal texts.
2. **Dynamic Storage Auditing:** To construct a browser scanner identifying pre-consent violations in both HTTP cookies and HTML5 Web Storage APIs.
3. **Discrepancy Engine Implementation:** To build a module that explicitly cross-references theoretical policy claims with live tracking payloads to expose ignored opt-outs.
4. **Empirical Evaluation:** To test this application against a benchmark dataset of highly frequented global domains to assess the current state of digital compliance.

What is the scope/coverage level/depth of the study? The scope is highly focused, targeting a benchmark dataset (N=15) of heavily frequented global domains across diverse industries, including technology (Google, Microsoft), social media (Meta, TikTok), e-commerce (Temu, Amazon), media (The New York Times), and government (USA.gov). This allows the study to evaluate varying web architectures and international compliance standards.

What methodology was used? The study utilizes a combined methodology of software engineering and empirical data analysis. The application was developed using HTML, CSS, and vanilla JavaScript for a localized execution engine utilizing Web Workers. The textual analysis methodology relies on Regular Expressions (Regex) for contextual keyword extraction and risk tiering, specifically programmed to understand negation and mandatory vs. optional data collection context. The dynamic auditing methodology extracts active storage events utilizing the Chrome Cookies API and algorithmic categorization.

What is the structure of the thesis - main chapters and their content? The thesis is structured into six chapters:

- **Chapter 1 (Introduction):** Outlines the background, problem statement, and specific research objectives.
- **Chapter 2 (Theoretical Framework):** Explores GDPR regulations, the technical mechanics of tracking (cookies vs. HTML5 storage), and the taxonomy of Dark Patterns.
- **Chapter 3 (Methodology):** Details the system architecture, NLP integration, dynamic cookie auditing, and the ethical justifications for localized data processing.
- **Chapter 4 (Results):** Presents quantitative findings, text analysis metrics, pre-consent baseline auditing, and GUI visual diagnostics across the benchmark dataset.

- **Chapter 5 (Discussion):** Synthesizes the findings, highlighting architectural evasion tactics (e.g., Temu, TikTok, Meta) and the economic drivers of compliance theater.
- **Chapter 6 (Conclusions):** Summarizes findings, acknowledges technical limitations (like SPA rendering blockers), and proposes future work.

(b) Theoretical Component

How/where was the theoretical documentation conducted? Theoretical documentation was conducted utilizing academic databases and official legislative repositories, including publications from the Association for Computing Machinery (ACM), scholarly articles via Google Scholar, and official European Union journals.

What are the main types of bibliographic sources used? The primary sources utilized are peer-reviewed academic articles regarding privacy engineering, official legislative documents (such as the GDPR and the ePrivacy Directive), and standardized technical documentation from the Internet Engineering Task Force (IETF) and the World Wide Web Consortium (W3C).

What are the main theories/approaches/ideas in literature?

Key theoretical concepts analyzed include:

- **Information Asymmetry and Privacy by Default:** The regulatory requirements of the GDPR mandating clear, unambiguous consent before data processing begins.
- **Stateful vs. Stateless Tracking Mechanics:** The technological evolution from first-party/third-party HTTP cookies to modern evasion techniques like HTML5 Web Storage APIs and browser fingerprinting.
- **Deceptive Design & Compliance Theater:** The taxonomy of Dark Patterns (visual interference, obstruction) and the deliberate disconnect between user interfaces (Consent Management Platforms) and actual Document Object Model (DOM) execution.

Is literature extensive or scarce on the topic? Are the existing works in agreement or conflicting? Literature is extensive regarding both the legal interpretation of the GDPR and the fundamental engineering of digital tracking. Existing works are generally in agreement that a conflict exists between user interfaces and browser execution, acknowledging that consent pop-ups frequently fail to alter back-end data flows. However, there is a scarcity of user-friendly, real-time diagnostic tools capable of mitigating this issue on the client side.

Where does the student's work fit within the broader literature? How did the literature contribute to the student's own analysis and original conclusions? This thesis fits squarely at the intersection of business informatics, software engineering, and digital law. The literature regarding the taxonomy of Dark Patterns and storage evasion directly informed the logic rules built into the application's discrepancy engine. By understanding how current regulatory enforcement relies on performative

legal documents, the author was able to conclude that technical, client-side automated auditing is a mandatory evolution for digital privacy.

(c) Case Study / Applied Component

What were the research objectives? The applied objective was to dynamically evaluate the benchmark dataset to observe if stated privacy rules matched technical reality, thus capturing and visualizing evasive tracking tactics in real-time.

How was the research conducted and why was a particular approach chosen? The research utilized a combined, descriptive, and exploratory approach. The client-side extension monitored user interaction (e.g., clicking "Reject All" on a CMP) and simultaneously recorded HTTP cookie and local storage activity in the browser's background. This localized, zero-interaction state baseline testing was chosen to strictly audit the GDPR mandate of "Privacy by Default," checking if payloads executed before consent was legally provided.

What are the main findings? The empirical analysis revealed widespread "compliance theater".

- **Fabricated Consent States:** Domains like Temu actively pre-initialized internal HTTP consent records to "Accepted" and actively ignored explicit user opt-out choices, injecting 14 active tracking cookies regardless of user input.
- **Evasive Local Storage:** TikTok demonstrated advanced tracking evasion by bypassing HTTP cookies and utilizing HTML5 localStorage to maintain 52 local tracking entries prior to authorization, rendering standard cookie-blockers obsolete.
- **Unverifiable Architectures:** Platforms like Meta and OpenAI managed consent exclusively via opaque server-side architectures, providing no technical means for the user to verify if opt-out requests were genuinely respected locally.

What are the contributions and implications of the research? The research explicitly proves that regulatory frameworks relying on company self-reporting and mandatory UI banners are insufficient and easily subverted. It contributes a viable proof-of-concept for automated, client-side technical auditing. It implies that future digital privacy protection must move away from notional legal compliance towards verifiable software diagnostics driven by users or independent researchers.

Problems encountered (e.g., limited access to literature/data, time/place constraints)

Several technical limitations were encountered during application development and testing:

1. **Extraction Barriers:** The static NLP module struggled to extract privacy text hidden behind strict "Cookie Walls" or rendered asynchronously via Single-Page Application (SPA) frameworks like React (evidenced by the Samsung policy yielding only 185 characters).

2. **Sandbox Limitations:** The Chrome Manifest V3 sandbox restricted the auditing tool to client-side storage mechanisms (cookies, localStorage). Therefore, the extension could not detect data harvested through unseen server-to-server APIs (e.g., Meta Conversions API).
3. **Semantic Depth:** The localized, regex-based NLP engine, while prioritizing user data security, lacked the deep semantic comprehension of a cloud-based Large Language Model (LLM), occasionally struggling with complex legal syntax.

Selective Bibliography

- Adhikari, A., Das, S. & Dewri, R., 2025. Natural Language Processing of Privacy Policies: A Survey. *arXiv preprint*, pp. 1-27.
- Barth, A., 2011. The HTTP state management mechanism, RFC 6265. *Internet Engineering Task Force (IETF)*.
- Englehardt, S. & Narayanan, A., 2016. Online Tracking: A 1-million-site Measurement and Analysis. *New York, Association for Computing Machinery*, pp. 1388-1401.
- European Parliament and Council of the European Union, 2002. Directive 2002/58/EC of the European Parliament and of the Council of 12 July 2002 concerning the processing of personal data and the protection of privacy in the electronic communications sector (Directive on privacy and electronic communications). *Official Journal of the European Union*, pp. 37-44.
- European Parliament and Council of the European Union, 2016. Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons about the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC. *Official Journal of the European Union*, pp. 1-88.
- Google, 2026. Migrate to Manifest V3. [Online] Available at: <https://developer.chrome.com/docs/extensions/develop/migrate>
- Gray, C. M. et al., 2018. The Dark Side of UX Design (Patterns). *Montreal, s.n.*, pp. 1-14.
- Klonick, K., 2025. BAN COOKIE BANNERS: A CASE STUDY IN TECH. *Harvard Journal of Law & Technology*, 39(1), pp. 1-37.
- Ling, Y. et al., 2022. Are they Toeing the Line? Diagnosing Privacy Compliance Violations among Browser Extensions. *Rochester, s.n.*, pp. 1-12.
- Matte, C., Bielova, N. & Santos, C., 2020. Do Cookie Banners Respect My Choice? : Measuring Legal Compliance of Banners from IAB Europe's Transparency and Consent Framework. *San Francisco, s.n.*, pp. 791-809.
- Mowery, K. & Shacham, H., 2012. Pixel Perfect: Fingerprinting Canvas in HTML5. *Proceedings of the Web 2.0 Security and Privacy Workshop*.
- Nouwens, M. et al., 2020. Dark Patterns after the GDPR: Scraping Consent Pop-ups and Demonstrating their Influence. *Honolulu, HI, USA, s.n.*, pp. 1-13.

- Sanchez-Rola, I., Santos, I. & Balzarotti, D., 2017. Extension Breakdown: Security Analysis of Browser Extension Resources Control Policies. *Vancouver, BC, Canada, s.n.*, pp. 1-17.
- Soe, T. H., Nordberg, O. E., Guribye, F. & Slavkovik, M., 2020. Circumvention by design - dark patterns in cookie consent for online news outlets. *Tallinn, Estonia, s.n.*, pp. 1-12.
- Trevisan, M., Traverso, S., Bassi, E. & Mellia, M., 2019. 4 Years of EU Cookie Law: Results and Lessons Learned. *PROCEEDINGS ON PRIVACY ENHANCING TECHNOLOGIES*, 2019(2), pp. 126-145.
- Urban, T., Degeling, M., Holz, T. & Pohlmann, N., 2020. Beyond the Front Page: Measuring Third-Party Dynamics in the Field. *Taipei, Taiwan, Association for Computing Machinery*, pp. 1275-1286.
- Utz, C. et al., 2019. (Un)Informed Consent: Studying GDPR Consent Notices in the Field. *London, Association for Computing Machinery*, pp. 973-990.
- World Wide Web Consortium, 2016. Web Storage (Second Edition), *s.l.: W3C Recommendation*.
- World Wide Web Consortium, 2026. Global Privacy Control (GPC). Available at: <https://www.w3.org/TR/gpc/>
- Zaeem, R. N. et al., 2020. PrivacyCheck v2: A Tool that Recaps Privacy Policies for You. *Virtual Event Ireland, s.n.*, pp. 3441-3444.